BÁO CÁO CHI TIẾT DANH SÁCH LỖI (BUG REPORT)

TÍNH NĂNG FR-17: QUẢN LÝ MÃ GIẢM GIÁ (COUPON CRUD) (POOL C)

- **Mã sinh viên:** 23120127
- **Họ và tên:** Dương Trọng Hòa
- **Hệ thống được kiểm thử (SUT):** EShop Platform (`http://localhost:5173` / Backend API `http://localhost:3000`)
- **Tổng số lỗi phát hiện:** 5 nhóm lỗi (1 Critical, 3 High, 1 Low/Medium)
- **Ngày lập báo cáo:** 2026-10-18

DANH SÁCH CHI TIẾT CÁC LỖI ĐÃ PHÁT HIỆN

🚨 BUG #1: BUG-FR17-01 (CRITICAL - SECURITY / BROKEN ACCESS CONTROL)

- **Tiêu đề Issue:** `[FR-17][SEC-03][CRITICAL] Lỗ hổng Broken Access Control cho phép người dùng thường tự tạo và xóa mã giảm giá`
- **Nhãn (Labels):** `bug`, `critical`, `security`, `FR-17`, `access-control`
- **Mức độ nghiêm trọng (Severity):** Critical (Lỗ hổng bảo mật nghiêm trọng - Kiểm soát truy cập bị phá vỡ)
- **Mức độ ưu tiên (Priority):** Urgent / Immediate
- **Môi trường:** Chrome / Windows / EShop Local (Backend API `http://localhost:3000`)

1. Mô tả lỗi

Theo đặc tả FR-12 và SEC-03:

> *"Tất cả các chức năng quản trị trong Web Admin (bao gồm thêm mới và xóa mã giảm giá) chỉ dành riêng cho tài khoản có vai trò Quản trị viên (role = 'admin'). Người dùng thông thường (role = 'user') hoàn toàn bị cấm truy cập."*

Tuy nhiên, kiểm tra mã nguồn Backend tại `backend/server.js`:

- Endpoint `POST /api/admin/coupons` (dòng 457) chỉ sử dụng middleware `authenticateToken` để kiểm tra đăng nhập mà **hoàn toàn không kiểm tra** `req.user.role === 'admin'`.
- Tương tự, endpoint `DELETE /api/admin/coupons/:id` (dòng 483) cũng chỉ xác thực Token thông thường.

Hậu quả: Một tài khoản người dùng bình thường (`test@eshop.com`, `role = 'user'`) có thể gửi HTTP request tạo mã giảm giá 1.000.000 ₫ hoặc xóa sạch toàn bộ mã giảm giá của hệ thống, gây thiệt hại tài chính và làm gián đoạn vận hành của cửa hàng!

2. Các bước tái hiện (Steps to Reproduce)

1. Đăng nhập với tài khoản người dùng thường: `test@eshop.com` / `Test1234!` để lấy JWT Token (`role = 'user'`).

2. Gửi request `POST /api/admin/coupons` với Header `Authorization: Bearer <user_token>` và payload:

```
{
  "code": "HACKER1000K",
  "discount_type": "fixed",
  "discount_value": 1000000,
  "min_order_amount": 0,
  "max_uses_per_user": 100
}
```

3. Quan sát phản hồi API: Trả về HTTP 200 OK `"Coupon created successfully"`.
4. Gửi request `DELETE /api/admin/coupons/:id` bằng Token người dùng thường: Trả về HTTP 200 OK `"Coupon deleted"`.

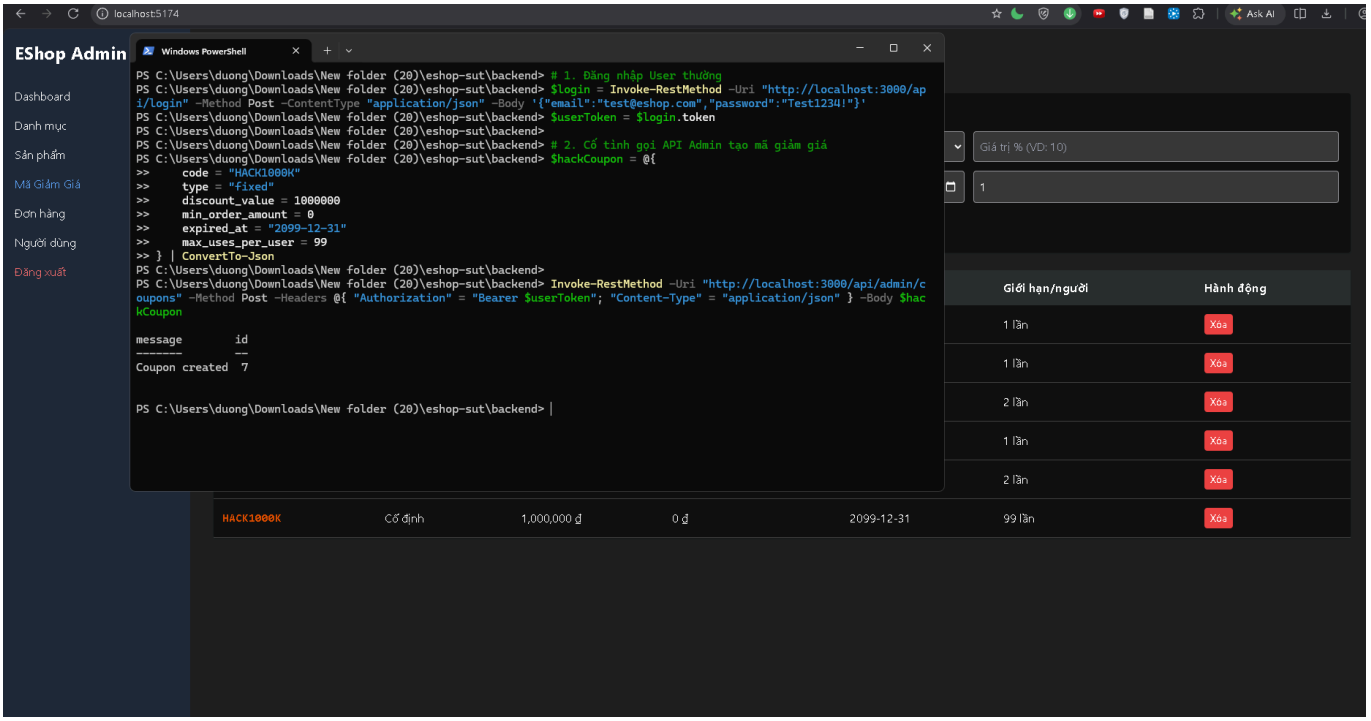
3. Kết quả mong đợi (Expected Result)

Hệ thống phải kiểm tra vai trò Quản trị viên và từ chối mọi yêu cầu từ tài khoản thường với mã lỗi **HTTP 403 Forbidden**:

4. Kết quả thực tế (Actual Result)

5. Bằng chứng hình ảnh (Screenshot)

- **Ảnh minh chứng:** `EXE-04_Bug_Critical_NonAdmin_Create_Coupon.png`



BUG #2: BUG-FR17-02 (HIGH - UNHANDLED EXCEPTION / CRASH ON DUPLICATE CODE)

- **Tiêu đề Issue:** `[FR-17][HIGH] Backend gặp lỗi 500 Internal Server Error và văng exception SQLite khi tạo mã giảm giá bị trùng lặp`
- **Nhãn (Labels):** `bug`, `high`, `backend`, `FR-17`, `error-handling`
- **Mức độ nghiêm trọng (Severity):** High (Lỗi sập luồng xử lý do không bắt ngoại lệ CSDL)
- **Mức độ ưu tiên (Priority):** High
- **Môi trường:** Chrome / Windows / EShop Local (Backend API `http://localhost:3000`)

1. Mô tả lỗi

Trong bảng `coupons` của SQLite, cột `code` được cấu hình ràng buộc `UNIQUE` (`code TEXT UNIQUE NOT NULL`). Khi Quản trị viên nhập mã giảm giá bị trùng với mã đã có trong hệ thống (ví dụ: `WELCOME10`), Backend `server.js` (dòng 460-475) thực hiện câu lệnh `INSERT` mà không kiểm tra sự tồn tại của mã trước, cũng không bắt mã lỗi ngoại lệ `SQLITE_CONSTRAINT: UNIQUE constraint failed`.

Khi ngoại lệ xảy ra, câu lệnh `if (err) return res.status(500).json({ error: err.message })` đã trả về lỗi **HTTP 500 Internal Server Error** kèm stack trace lộ thông tin cấu trúc CSDL cho client.

2. Các bước tái hiện (Steps to Reproduce)

1. Đăng nhập tài khoản Quản trị viên (`admin@eshop.com`).
2. Gửi request tạo mã giảm giá với mã đã tồn tại sẵn trong CSDL:

```
{
  "code": "WELCOME10",
  "discount_type": "percent",
  "discount_value": 10,
  "min_order_amount": 100000,
  "max_uses_per_user": 1
}
```

3. Quan sát phản hồi API từ Backend.

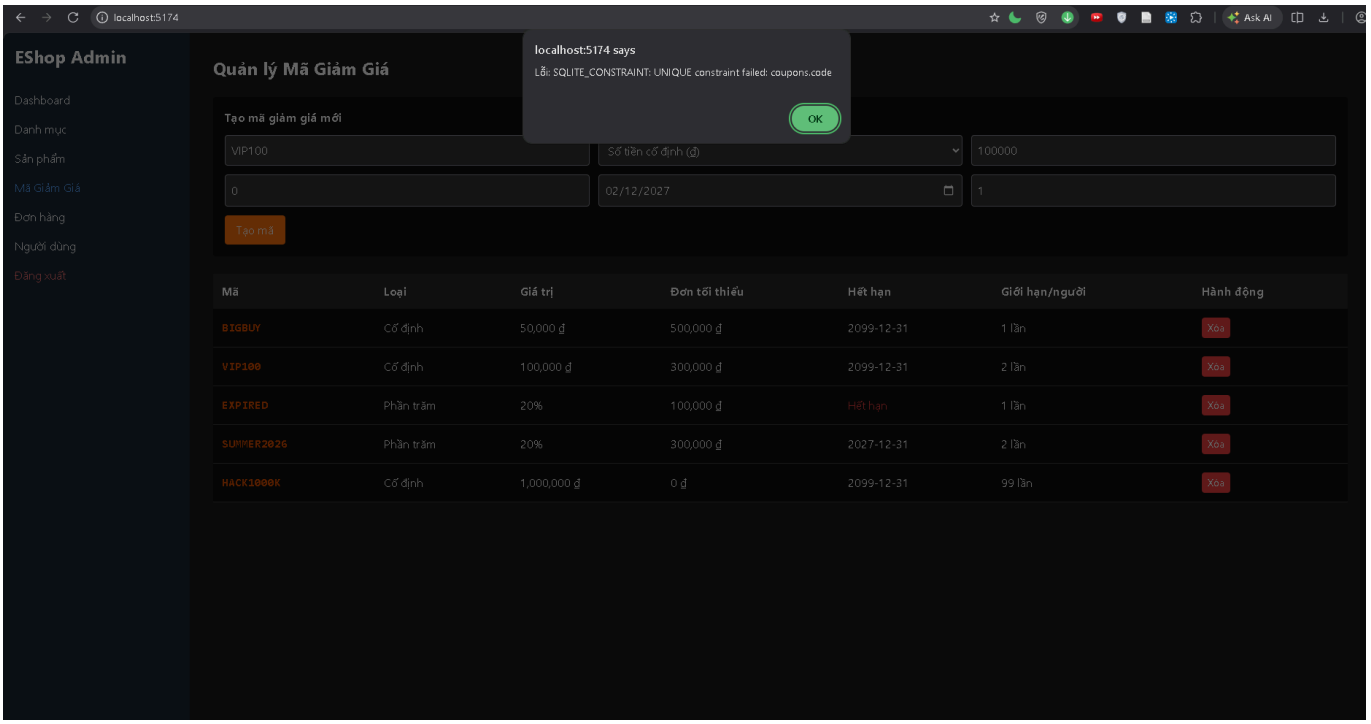
3. Kết quả mong đợi (Expected Result)

Hệ thống phải kiểm tra hoặc bắt lỗi vi phạm ràng buộc UNIQUE, trả về mã lỗi client hợp lệ **HTTP 400 Bad Request** hoặc **HTTP 409 Conflict** kèm thông báo thân thiện:

4. Kết quả thực tế (Actual Result)

5. Bằng chứng hình ảnh (Screenshot)

- **Ảnh minh chứng:** `EXE-07_Bug_Duplicate_Code_500_Error.png`



⚠️ BUG #3: BUG-FR17-03 (HIGH - MISSING BOUNDARY & INPUT VALIDATION FOR NUMERIC FIELDS)

- **Tiêu đề Issue:** `[FR-17][HIGH] Backend không kiểm tra ràng buộc số dương cho discount_value, min_order_amount và max_uses_per_user`
- **Nhãn (Labels):** `bug`, `high`, `backend`, `FR-17`, `data-validation`
- **Mức độ nghiêm trọng (Severity):** High (Lỗi tính toàn vẹn dữ liệu và vi phạm phân tích biên)
- **Mức độ ưu tiên (Priority):** High
- **Môi trường:** Chrome / Windows / EShop Local (Backend API `http://localhost:3000`)

1. Mô tả lỗi

Theo đặc tả nghiệp vụ FR-17:

- `discount_value`: Phải là số dương > 0 (mã giảm giá không thể giảm 0 ₫ hoặc giảm số tiền âm).
- `min_order_amount`: Phải là số không âm ≥ 0 (không thể có đơn hàng tối thiểu âm).
- `max_uses_per_user`: Phải là số nguyên dương ≥ 1 (mã phải dùng được ít nhất 1 lần).

Tuy nhiên, Backend `server.js` nhận toàn bộ dữ liệu từ body mà không có bất kỳ lệnh kiểm tra điều kiện nào:

1. Cho phép tạo mã giảm giá với `discount_value = 0` (EXE-08).
2. Cho phép tạo mã giảm giá với `discount_value = -50000` (EXE-09).
3. Cho phép tạo mã giảm giá với `min_order_amount = -10000` (EXE-11).
4. Cho phép tạo mã giảm giá với `max_uses_per_user = 0` (EXE-12). Nghiêm trọng hơn, khi tải lại trang Web Admin (F5), giao diện lại tự động hiển thị số `1`, dẫn đến sự bất nhất tai hại giữa dữ liệu thực trong CSDL (lưu 0) và giao diện hiển thị cho Quản trị viên (hiển thị 1).

2. Các bước tái hiện (Steps to Reproduce)

1. Dùng tài khoản Admin gọi API `POST /api/admin/coupons` với payload chứa giá trị biên vi phạm:

- Case 1: `discount_value: 0`
- Case 2: `discount_value: -50000`
- Case 3: `min_order_amount: -10000`
- Case 4: `max_uses_per_user: 0`

2. Quan sát phản hồi API và kiểm tra dữ liệu trong bảng `coupons` của SQLite.
3. Đối với Case 4, mở Web Admin xem danh sách coupon và nhấn F5 để kiểm tra hiển thị.

3. Kết quả mong đợi (Expected Result)

Backend phải validate dữ liệu và từ chối các giá trị không hợp lệ với mã lỗi **HTTP 400 Bad Request**:

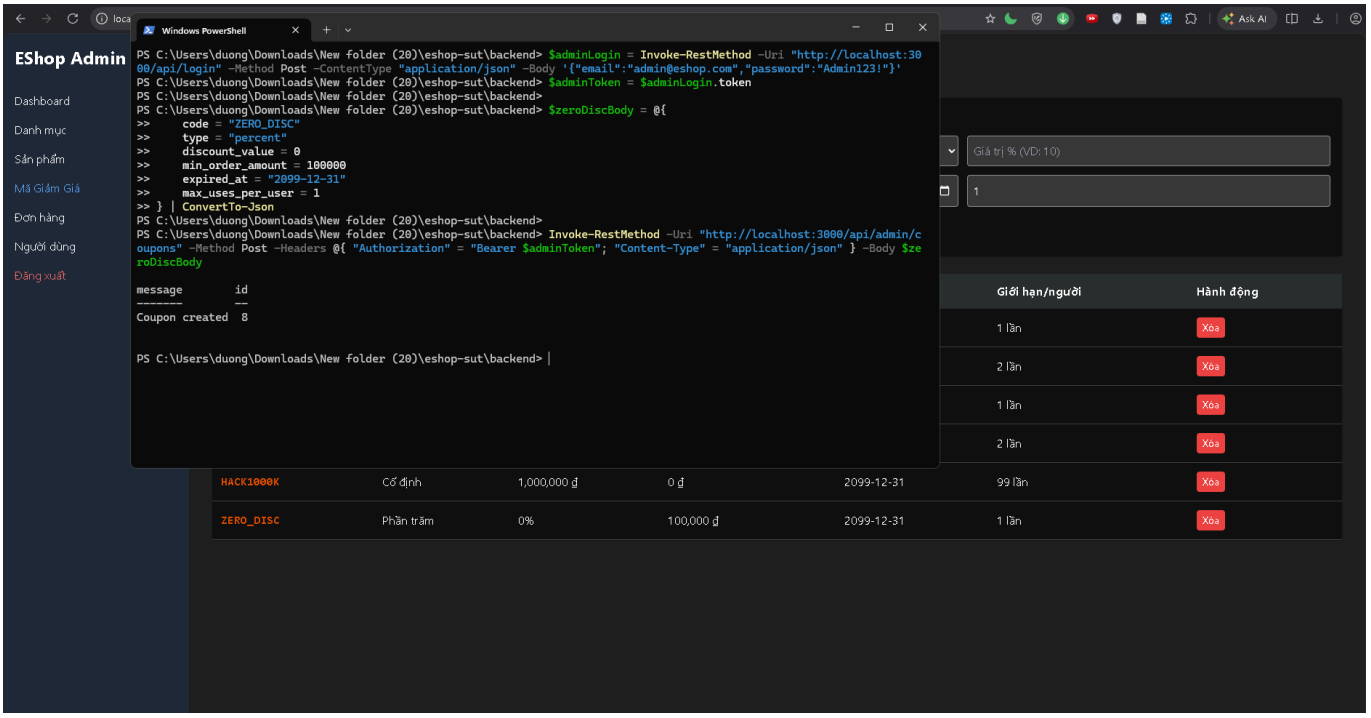
- `discount_value` phải là số dương > 0.
- `min_order_amount` phải là số nguyên ≥ 0.
- `max_uses_per_user` phải là số nguyên ≥ 1.

4. Kết quả thực tế (Actual Result)

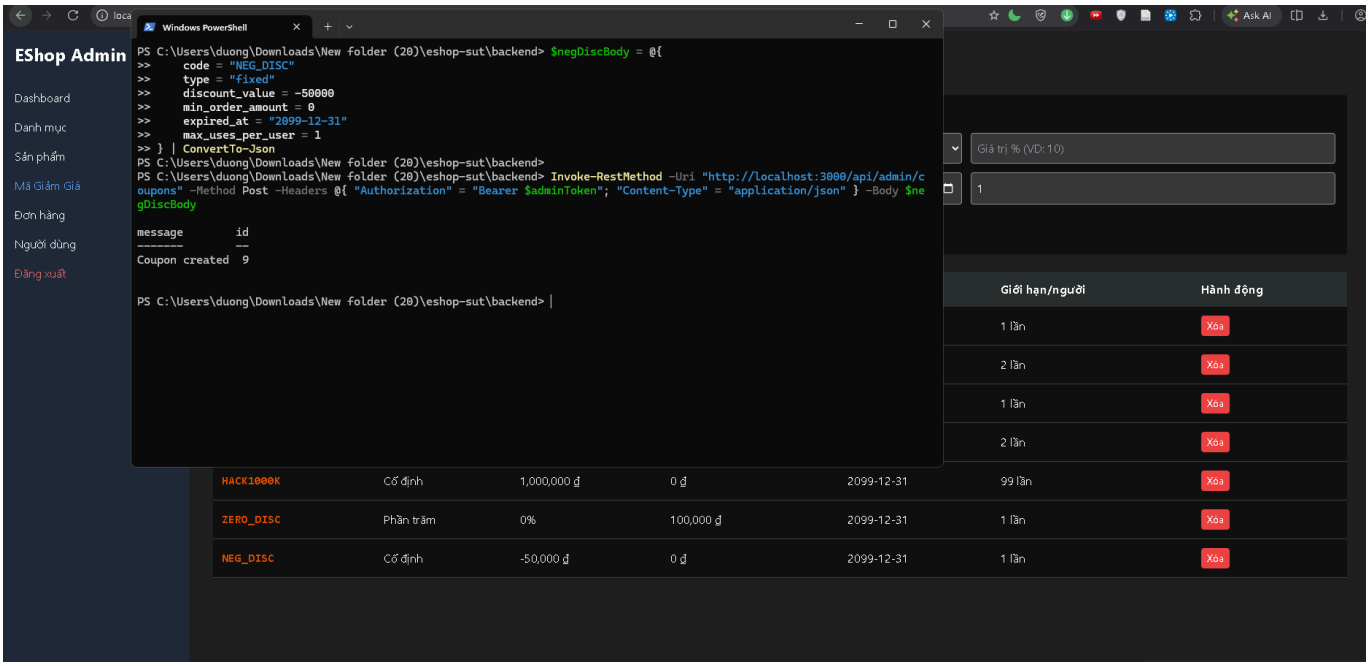
Tất cả các request trên đều được Backend chấp nhận với **HTTP 200 OK** và lưu thẳng vào SQLite. Tại Web Admin, mã có `max_uses_per_user = 0` bị render thành `1`.

5. Bằng chứng hình ảnh (Screenshot)

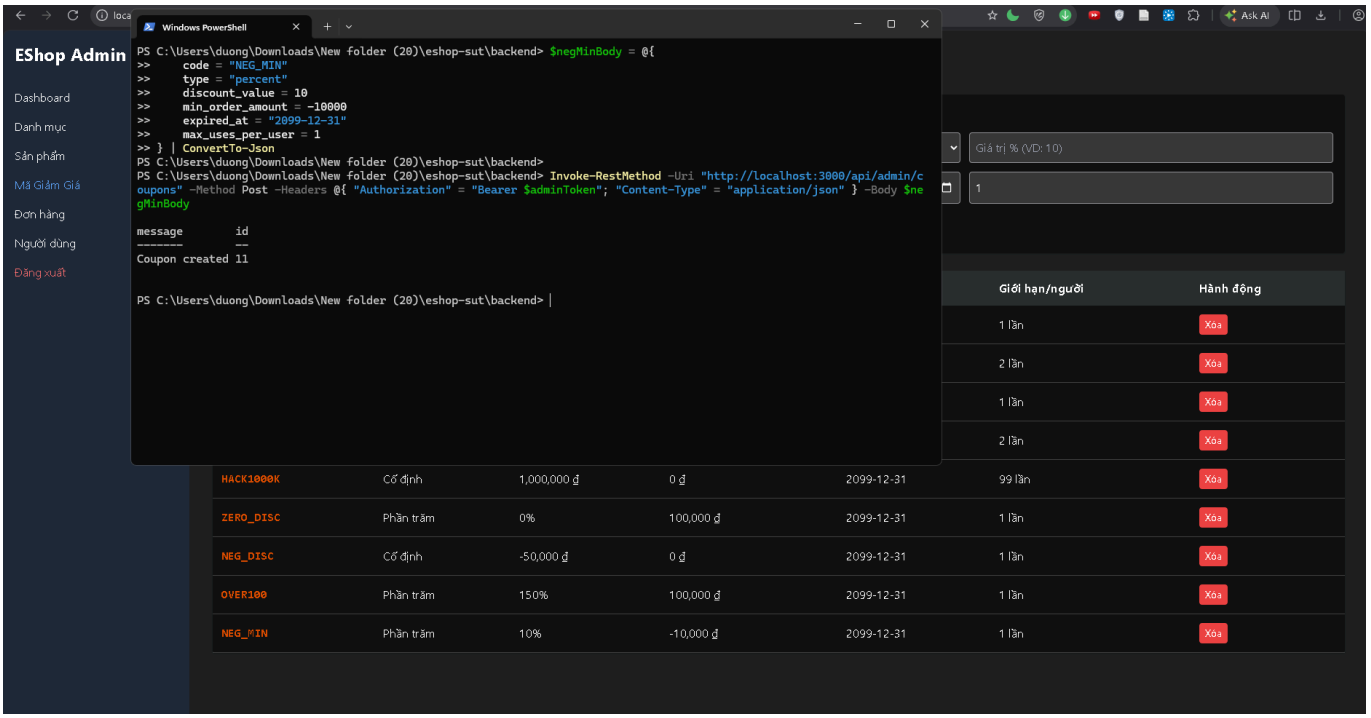
- **Ảnh minh chứng:** `EXE-08_Bug_BVA_DiscountValue_Zero_Accepted.png`



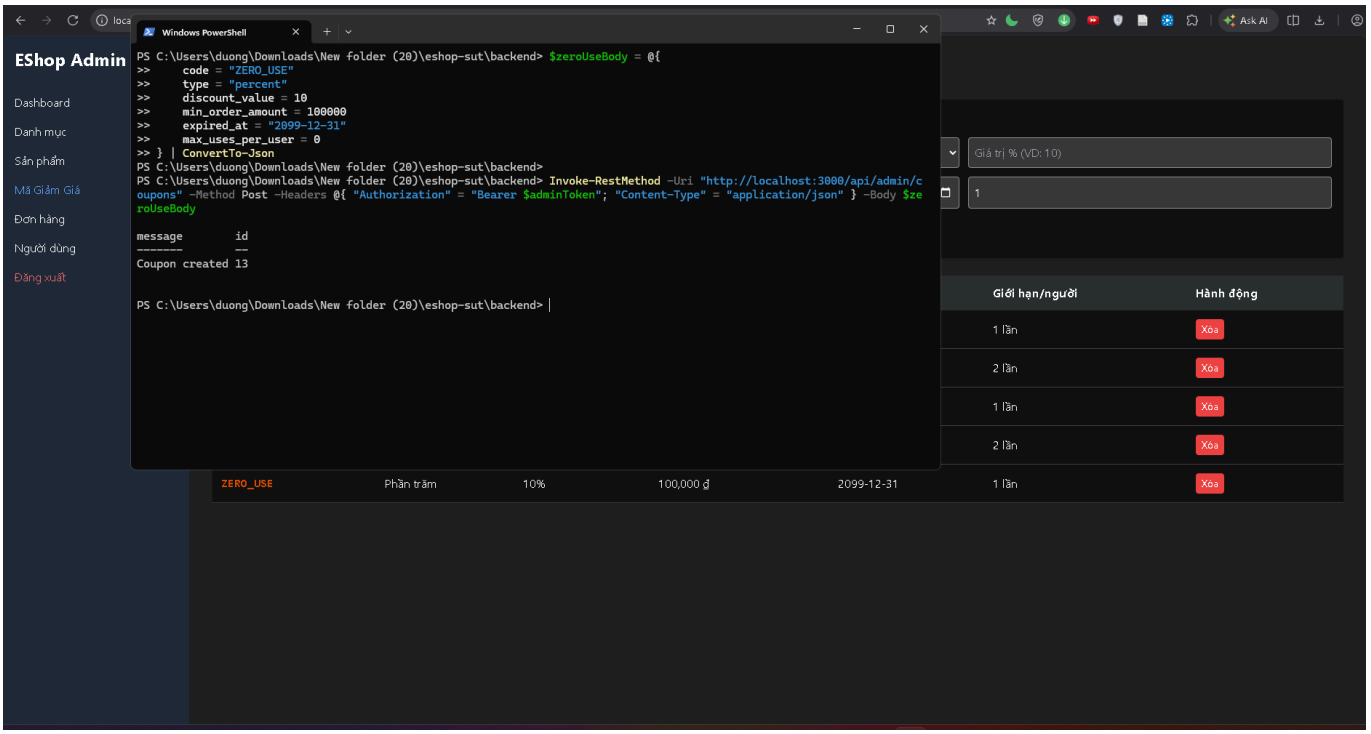
- **Ảnh minh chứng:** `EXE-09_Bug_Negative_DiscountValue_Accepted.png`



- **Ảnh minh chứng:** EXE-11_Bug_BVA_MinOrderAmount_Negative_Accepted.png



- **Ảnh minh chứng:** EXE-12_Bug_BVA_MaxUses_Zero_Accepted.png



6. Đề xuất khắc phục (Suggested Fix)

Thêm kiểm tra tính hợp lệ trước khi thực hiện câu lệnh Insert:

⚠️ BUG #4: BUG-FR17-04 (HIGH - PERCENT DISCOUNT EXCEEDS 100%)

- **Tiêu đề Issue:** `[FR-17][HIGH] Cho phép tạo mã giảm giá theo phần trăm vượt quá 100% (discount_value = 150%)`
- **Nhãn (Labels):** `bug`, `high`, `backend`, `FR-17`, `business-logic`
- **Mức độ nghiêm trọng (Severity):** High (Lỗi quy tắc nghiệp vụ tài chính)
- **Mức độ ưu tiên (Priority):** High
- **Môi trường:** Chrome / Windows / EShop Local (Backend API `http://localhost:3000`)

1. Mô tả lỗi

Theo nguyên lý thương mại điện tử và đặc tả FR-17:

> *"Đối với loại mã giảm giá theo phần trăm (discount_type = 'percent'), mức giảm giá hợp lệ phải nằm trong đoạn [1..100]%."*

Mức giảm phần trăm vượt quá 100% (ví dụ: 150%) sẽ dẫn tới việc số tiền giảm giá lớn hơn toàn bộ giá trị đơn hàng, làm tổng tiền thanh toán bị âm nếu hệ thống không có lớp chặn phụ trợ. Tuy nhiên, Backend `POST /api/admin/coupons` hoàn toàn không kiểm tra giới hạn trên (Max Boundary = 100) khi `discount_type === 'percent'`.

2. Các bước tái hiện (Steps to Reproduce)

1. Gửi request tạo coupon loại phần trăm với giá trị 150%:

```
{
  "code": "OVER100",
  "discount_type": "percent",
  "discount_value": 150,
  "min_order_amount": 100000,
  "max_uses_per_user": 1
}
```

2. Quan sát kết quả phản hồi của API.

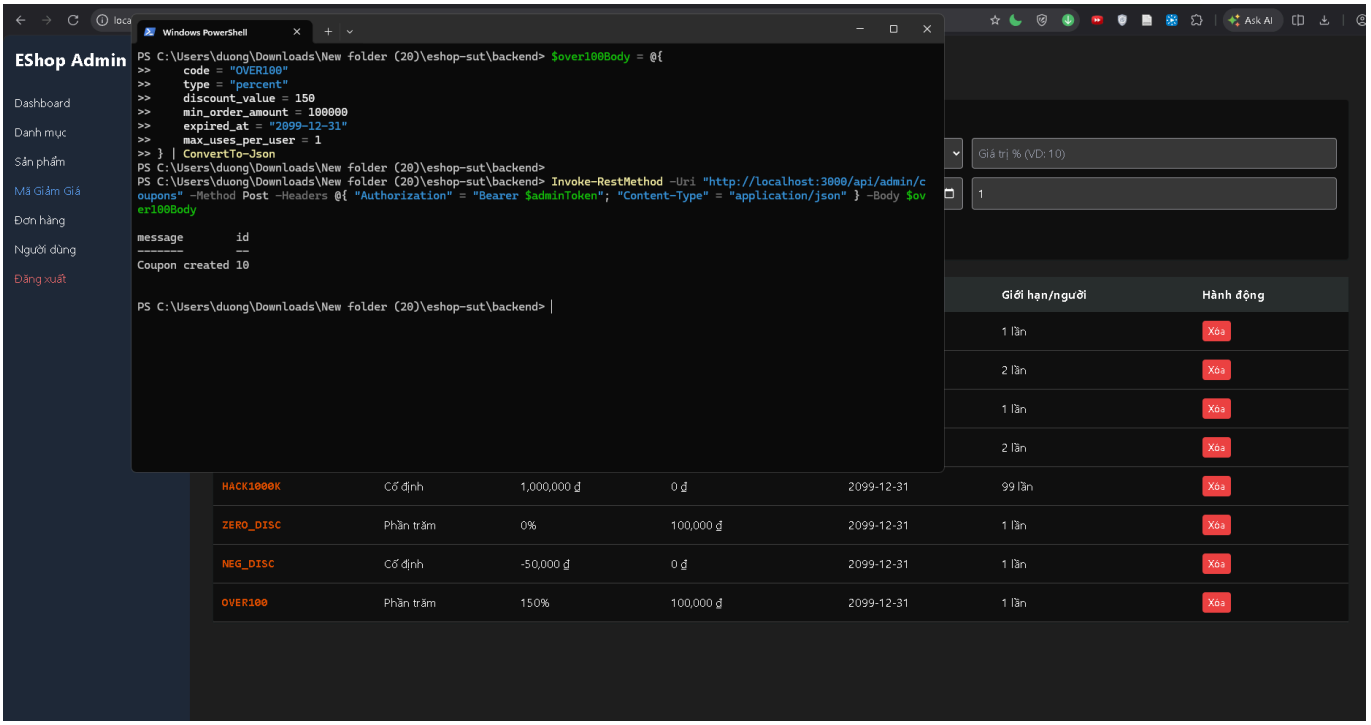
3. Kết quả mong đợi (Expected Result)

Hệ thống phải từ chối yêu cầu với mã lỗi **HTTP 400 Bad Request** kèm thông báo lỗi:

4. Kết quả thực tế (Actual Result)

5. Bằng chứng hình ảnh (Screenshot)

- **Ảnh minh chứng:** `EXE-10_Bug_BVA_Percent_Over100_Accepted.png`



ℹ️ BUG #5: BUG-FR17-05 (MEDIUM - REST API NON-EXISTENT COUPON DELETION RETURNS 200 OK)

- **Tiêu đề Issue:** `[FR-17][MEDIUM] Xóa mã giảm giá với ID không tồn tại trả về HTTP 200 OK thay vì HTTP 404 Not Found`
- **Nhãn (Labels):** `bug`, `medium`, `backend`, `FR-17`, `restful-api`
- **Mức độ nghiêm trọng (Severity):** Medium (Vi phạm chuẩn thiết kế RESTful API)
- **Mức độ ưu tiên (Priority):** Medium
- **Môi trường:** Chrome / Windows / EShop Local (Backend API `http://localhost:3000`)

1. Mô tả lỗi

Khi thực hiện xóa một tài nguyên không tồn tại thông qua phương thức `DELETE /api/admin/coupons/:id`, chuẩn RESTful API quy định hệ thống phải phản hồi mã **HTTP 404 Not Found** để thông báo cho phía client biết tài nguyên cần thao tác không có trong hệ thống.

Tuy nhiên, tại `backend/server.js` dòng 483-490:

2. Các bước tái hiện (Steps to Reproduce)

3. Kết quả mong đợi (Expected Result)

4. Kết quả thực tế (Actual Result)

5. Bằng chứng hình ảnh (Screenshot)

- **Ảnh minh chứng:** `EXE-13_Bug_Delete_NonExistent_ID_200OK.png`

